

CSD380: DevOps  
Module 11: Deployment Pipeline II  
Assignment 2: Compliance  
Isaac Ellingson  
8/2/2026

# **Security and Compliance Using Telemetry**

Two Case Studies

# Providing Compliance in Regulated Environments

This case study follows Amazon and their AWS platform. They were trying to open their systems to make compliance audits possible, so their cloud systems could be used for things requiring HIPAA compliance, for example - but this could extend all the way out to something ubiquitous like the GDPR. If you can't make auditing information available in a way that compliance auditors can recognize, you lose a big chunk of your client base.

But what auditors are used to working with is screenshots and CSV files, like if you've got a thousand servers, pick a representative sample of a hundred and pull compliance evidence from that sample. If servers are being spun up and shut down on demand, if they're virtualized, if they're not reliably in one physical datacenter and instead accessed over the cloud, this requires some kind of adaptation from the auditors.

Making the process easier for them is also challenging - compliance requirements are usually some kind of legal document, they're often large and arcane, require domain knowledge, and you'd need to spend a lot of engineering time trying to do it yourself. Two things helped: First, working directly with the auditors and compliance officers to understand their needs. Second, taking all the information they *do* have and funnelling it into their existing telemetry systems so that it can be processed and digested into useful compliance evidence.

They had more than enough telemetry to produce the needed evidence. In fact, many times more data, like chat logs, error logs, deployment pipeline logs, telemetry from running systems, you have a multitude of data that can corroborate each other and produce a very solid compliance guarantee, if you can just get it in one place and formatted in an understandable way.

So ultimately, all you need to do is get everyone talking and collaborating on compliance, get the telemetry data together, and provide the tools and controls to format that data in the right way to produce evidence.

# Relying on Production Telemetry for ATM Systems

This case study follows a large, unnamed financial services organization. I assume it is not named because they want to avoid disclosure of details about their security process and historical security incidents. However, it does make it more difficult to trust or verify the case study.

The concern here is safety and security. Everyone knows the Office Space story, where one of the programmers within the organization writes a backdoor to steal money. In fact, this organization *did* wind up in a situation where a developer had inserted a backdoor, and was putting ATMs into maintenance mode to withdraw arbitrary amounts of money without debiting their accounts. This is a real, plausible threat that you're going to have when you're handling high-value assets that might give programmers an incentive to cheat.

<https://github.com/apache/maven>

The main point in the case study is how this event was resolved. Nobody found the backdoor. Even good code review processes can't necessarily surface a skillful and motivated attack from within. Even if your review process is perfect, you've increased your minimum conspiracy size by one. It's not good enough. They actually found this using their telemetry - ATMs were going into maintenance mode at the wrong times, when maintenance wasn't scheduled.

Two things I have to say about this: One, telemetry doesn't help you if it's not monitored. They did a fantastic job of catching this quickly because *\*someone was looking at it\**. Second, it can be really hard to know what you're looking for in telemetry. Who knew that recording the maintenance mode activation times would result in prompt fraud detection! So the more you collect, and the better your processing and heuristics are, the better your outcomes will be. Keep refining those heuristics as you collect more data and have more field experience.

Interesting case studies, making a good case for telemetry. I'm not often a big fan of telemetry because of the security and privacy implications, but in both cases here they were used internally to create a more secure and responsible product. I don't hate that.

## References

Kim, G., Humble, J., Debois, P., Willis, J., & Forsgren, N. (2021). *The DevOps handbook, second edition*. IT Revolution.